

Informe de Políticas de Seguridad - Data Loss Prevention (DLP)

Fecha: 13 de julio 2026.

Elaborado por: Claudia Larrea

Índice

I. Informe de Políticas de Seguridad: Control de Acceso al uso de dispositivos USB aplicando el Principio de mínimo Privilegio.	3
i. Introducción al Data Loss Prevention.	3
ii. Clasificación de datos	3
iii. Acceso y Control	4
a. Políticas de Acceso Basadas en el Menor Privilegio	4
b. Flujo de Revisión de Permisos	4
c. Roles Responsables y Procedimientos	5
iv. Herramientas de Monitoreo y Auditoría	5
v. Prevención de filtraciones	6
vi. Educación y Concientización	6
II. Implementación de Políticas de Restricción de Dispositivos USB	7
i. Configuración de Restricciones en Windows	7
ii. Habilitación de Excepciones para Usuarios Específicos	8
III. Conclusión general	8

I. Informe de Políticas de Seguridad: Control de Acceso al uso de dispositivos USB aplicando el Principio de mínimo Privilegio.

i. Introducción al Data Loss Prevention.

El Data Loss Prevention (DLP), se define como un conjunto de estrategias, políticas y herramientas tecnológicas diseñadas para proteger la información de una organización contra acceso no autorizado, filtraciones, pérdidas o que sea utilizada de manera indebida.

Su objetivo principal es identificar, monitorear y controlar el movimiento de los datos, tanto dentro de la infraestructura de la organización como cuando estos se transfieren hacia dispositivos externos, aplicaciones en la nube o redes públicas.

En el contexto actual, donde las organizaciones gestionan grandes volúmenes de información digital, la protección de los datos se ha convertido en un aspecto fundamental de la seguridad. La pérdida o divulgación de información sensible puede ocasionar daños económicos, sanciones legales, pérdida de reputación y comprometer la confianza de clientes y socios comerciales.

Las soluciones DLP permiten establecer políticas de seguridad basadas en el tipo de información que se desea proteger, de forma de supervisar el uso de los datos y aplicar acciones preventivas. De esta manera, el DLP contribuye a reducir el riesgo de fugas de información, garantizar el cumplimiento de normativas de protección de datos y fortalecer la seguridad de la organización.

ii. Clasificación de datos

Para implementar una estrategia de DLP eficaz, la organización deberá clasificar la información de acuerdo con su nivel de sensibilidad y con el impacto que podría generar su divulgación, modificación o pérdida. Esta clasificación permitirá definir las medidas de protección adecuadas para cada tipo de dato y aplicar controles de seguridad acordes a su nivel de criticidad.

En este sentido se pueden establecer las siguientes categorías:

- **Datos Públicos:** es la información que puede ser divulgada libremente sin representar riesgos para la organización. Su acceso está permitido para cualquier persona. Ejemplos: Información publicada en el sitio web institucional, material publicitario, entre otros.
- **Datos Internos:** aquí se incluye la información destinada al uso exclusivo de los empleados de la organización. Su acceso debe limitarse al personal autorizado. A modo de ejemplo: procedimientos internos, manuales de usuario, entre otros.
- **Datos Sensibles:** esta categoría comprende la información cuya divulgación, alteración o pérdida podría generar un impacto significativo para la organización,

sus clientes o sus empleados. Estos datos requieren controles de seguridad más estrictos y solo deben ser accesibles por personal autorizado. Ejemplos: datos personales de clientes y empleados, información financiera y contable, propiedad intelectual, información estratégica de la organización, entre otros.

iii. Acceso y Control

Para garantizar la seguridad de la información en la organización la implementación de políticas de acceso basadas en el Principio del Menor Privilegio busca asegurar que cada persona posea únicamente los permisos estrictamente necesarios para desempeñar sus funciones. A continuación, se detallan las políticas de acceso y el flujo de revisión de permisos:

a. Políticas de Acceso Basadas en el Menor Privilegio

El acceso a la información se estructurará siguiendo la clasificación de datos de la organización.

- Acceso restringido: Los empleados tendrán acceso exclusivo a los documentos y carpetas necesarios para desempeñar sus tareas diarias.
- Permisos de edición limitados: se otorgarán permisos de edición únicamente a los responsables directos de los proyectos o documentos. Los demás empleados consultarán la información bajo la modalidad de solo lectura.
- Gestión de acceso temporal: Para proyectos específicos que involucren documentos sensibles, se concederá acceso temporal mediante una autorización escrita y por personal superior, el cual será revocado inmediatamente al finalizar la tarea.
- Protección contra descargas: se deben implementar controles de software que impidan la copia de archivos con etiquetas de "Confidencial" o "Solo para uso interno" hacia memorias USB.
- Desactivación de puertos: los puertos USB en estaciones de trabajo críticas estarán deshabilitados de forma predeterminada.
- Concientización: Los programas de capacitación obligatorios incluirán módulos específicos sobre los riesgos de los dispositivos USB, como la pérdida física de los mismos o la introducción de malware, reforzando las mejores prácticas para el manejo de información confidencial.

b. Flujo de Revisión de Permisos

El proceso de revisión se llevará a cabo de manera sistemática para detectar y corregir excesos de privilegios, mediante:

- Detección de anomalías: Se configurarán alertas automáticas que notificarán al departamento de seguridad en tiempo real si se conceden permisos inadecuados o se intenta compartir información confidencial fuera de la red autorizada.
- Auditoría trimestral: Cada seis meses se realizará una revisión exhaustiva de todos los permisos de acceso a archivos y carpetas.
- Validación de activos: Durante la auditoría, se verificará que solo el personal activo y debidamente autorizado conserve sus accesos, eliminando de inmediato aquellos que ya no sean necesarios.

c. Roles Responsables y Procedimientos

La responsabilidad de la seguridad y revisión de accesos se distribuye en tres niveles:

- Responsables de área: Son los encargados de asignar y validar los permisos de edición de su equipo, asegurando que solo los colaboradores necesarios tengan capacidad de modificar documentos.
- Departamento de seguridad: Es responsable de realizar las auditorías trimestrales, supervisar el registro de actividades y responder a las alertas de seguridad generadas por el sistema. También deben coordinar las capacitaciones obligatorias para concientizar al personal sobre el manejo seguro de los datos.
- Niveles directivos: Actúan como los custodios de los documentos sensibles (contratos, datos financieros), siendo los únicos facultados para autorizar accesos excepcionales a este tipo de información bajo estricta necesidad.

iv. Herramientas de Monitoreo y Auditoría

Soluciones de Data Loss Prevention (DLP):

- En la nube: Herramientas que aplican automáticamente la protección con etiquetas y restringen el uso compartido externo de forma predeterminada para archivos sensibles,
- En el endpoint (USB): software especializado que bloquea físicamente los puertos o cifra la información que se intenta copiar a dispositivos removibles.
- Sistemas SIEM: herramienta ideal para centralizar los registros de logs de uso de USB y correlacionar eventos. Por ejemplo, descarga de un archivo de la nube y simultáneamente conecta un USB.
- Panel de Alertas de Seguridad: Interfaz donde el departamento de seguridad recibe y gestiona en tiempo real las notificaciones de incumplimiento de políticas.

v. Prevención de filtraciones

Para evitar que la información sensible salga del control de la organización, se implementarán medidas técnicas y tecnológicas que actúan como barreras críticas:

- Desactivación de enlaces públicos: La opción de compartir archivos o carpetas mediante "cualquier persona con el enlace" quedará deshabilitada de forma predeterminada para todos los documentos clasificados como sensibles
- Control estricto de difusión: Solo se permitirá compartir documentos sensibles con empleados o socios externos que hayan sido previamente aprobados. En estos casos, el acceso se limitará estrictamente a permisos de solo lectura, eliminando cualquier opción de descarga o copia del archivo.
- Protección mediante etiquetas: Se utilizarán etiquetas de seguridad como "Confidencial" o "Solo para uso interno" para identificar y proteger los activos más críticos. Los documentos con estas etiquetas solo podrán ser descargados si el usuario cuenta con un permiso especial explícito.
- Restricciones físicas: como extensión de estas herramientas de DLP, se mantiene la política de bloqueo o restricción de puertos USB para evitar que documentos protegidos digitalmente sean extraídos físicamente de la organización.
- Cifrado: cifrar los datos busca asegurar que, incluso si un dato fuera interceptado, su contenido permanezca inaccesible para terceros no autorizados.

vi. Educación y Concientización

Para el éxito de las políticas de seguridad, el factor humano es esencial, por lo que se establecerá un programa continuo de formación, que consiste en:

- Capacitaciones obligatorias semestrales: Todo el personal deberá participar en sesiones de formación diseñadas para mantenerlos actualizados sobre las políticas y los protocolos para el manejo seguro de información.
- Concientización sobre riesgos: en las clases de capacitación se presentarán ejemplos de incidentes comunes, como el riesgo de compartir documentos accidentalmente con terceros ajenos a la empresa, para que los empleados comprendan las consecuencias prácticas de un descuido.
- Enfoque en mejores prácticas: La capacitación se centrará en enseñar las formas correctas y seguras de colaborar y compartir información dentro del marco de trabajo permitido

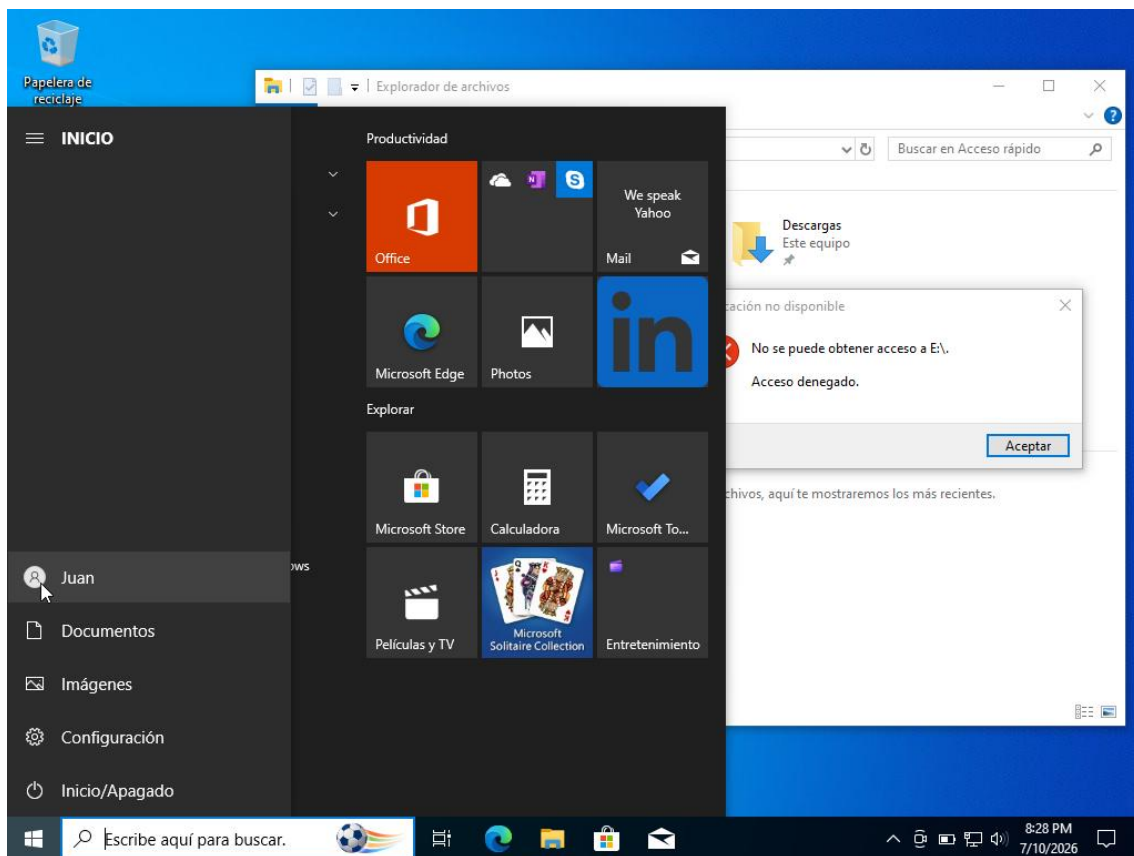
II. Implementación de Políticas de Restricción de Dispositivos USB

En esta segunda parte del informe se detalla la implementación técnica y la validación de las restricciones físicas de hardware, las cuales complementan las políticas de DLP y el Principio del Menor Privilegio establecidos en la organización.

i. Configuración de Restricciones en Windows

Con el objetivo de prevenir la extracción no autorizada de información, se implementaron configuraciones de seguridad a nivel del sistema, incluyendo la restricción de dispositivos de almacenamiento removible mediante la aplicación de políticas que bloquean las operaciones de lectura y escritura en dispositivos de almacenamiento USB.

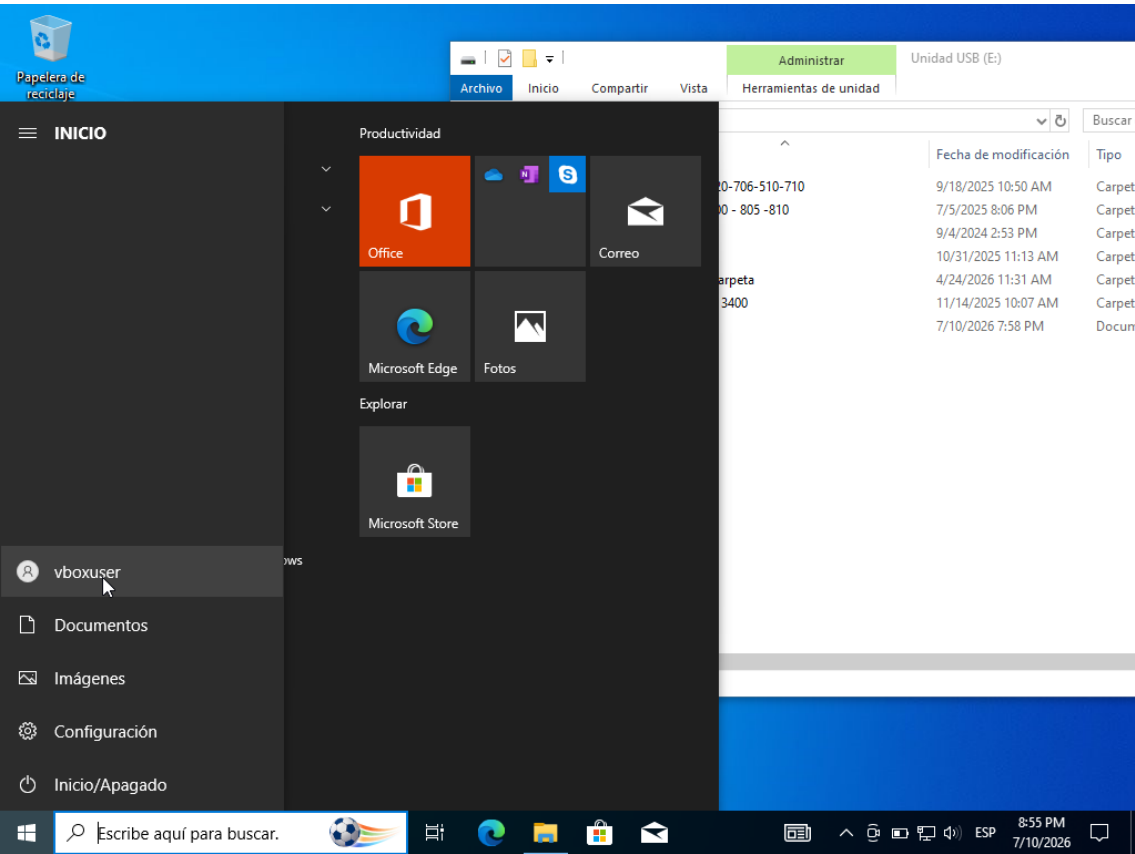
Para asegurar la efectividad de las políticas, se llevaron a cabo pruebas bajo distintos escenarios de usuario:



Al conectar un dispositivo USB, el sistema operativo denegó automáticamente el acceso. El usuario no pudo copiar, mover ni visualizar archivos desde o hacia el medio removible.

ii. Habilitación de Excepciones para Usuarios Específicos

Siguiendo el Principio del Menor Privilegio, se establecieron casos excepcionales donde el uso de USB es estrictamente necesario para funciones operativas. Para ello se crearon grupos de seguridad específicos para permitir el uso de USB únicamente a personal autorizado.



III. Conclusión general

La implementación de controles de seguridad orientados a la protección de la información y la restricción de dispositivos de almacenamiento removible representa un avance significativo en el fortalecimiento de la postura de seguridad de la organización. Estas medidas permiten establecer un enfoque integral de protección, reduciendo los riesgos asociados a la fuga de información y al acceso no autorizado.

La protección de los activos de información requiere considerar tanto los entornos digitales como los medios físicos utilizados para su transferencia. Mediante la aplicación de políticas de restricción sobre dispositivos USB, se disminuyen las posibilidades de extracción no autorizada de información sensible a través de medios externos, reforzando los mecanismos de prevención contra posibles incidentes de seguridad.

Asimismo, estas medidas contribuyen al cumplimiento del principio de menor privilegio, garantizando que los usuarios dispongan únicamente de los permisos y capacidades necesarias para desarrollar sus funciones.

La efectividad de estos controles se fortalece mediante actividades de supervisión, validación y auditoría periódica, permitiendo verificar su correcto funcionamiento.

Finalmente, que la estrategia de seguridad perdure en el tiempo depende también del compromiso y la concientización del personal. La capacitación continua permite reducir el impacto del factor humano y consolidar una cultura organizacional enfocada en la protección de la información.